

Gap Assessment Report

NCA ECC | AI Rajhi Technologies

Prepared for:	AI Rajhi Technologies
Industry:	Banking and Financial Services
Prepared by:	kayShahbaaz
Date:	27 August 2026
Classification:	CONFIDENTIAL

1. Executive Summary

AI?Rajhi Technologies achieved an overall compliance score of only 3?percent in the NCA?ECC assessment, with just one of the twenty?seven required controls fully satisfied and ten only partially met. The audit identified critical deficiencies, including the absence of a documented and approved cybersecurity strategy, a comprehensive inventory of hardware, software and data assets, regular risk assessments, formal risk?treatment plans aligned to a defined risk appetite, and the implementation of network segmentation, firewalls and traffic monitoring. These gaps place the organization in clear non?compliance with the National Cybersecurity Authority's Essential Cybersecurity Controls, as well as with related SAMA and PDPL obligations governing risk management and data protection. Immediate remediation is required to align the security program with Saudi regulatory expectations and to mitigate the substantial operational and reputational risks that currently exist.

Compliance Score:	4%
Total Controls:	27
Controls Met:	1
Partially Met:	10
Not Met:	16

2. Priority Action Plan

- [1-2] Cybersecurity Strategy: Missing documented cybersecurity strategy, evidence of its development, approval, implementation, and alignment with organizational objectives.
- [2-1] Asset Management: No evidence of identifying or maintaining an inventory of hardware, software, or data 2. assets.
- [2-2] Risk Assessment: No evidence of regular risk assessments to identify threats, vulnerabilities, and impacts is 3. provided.
- [2-3] Risk Treatment: Missing documented risk treatment plans and evidence of alignment with a defined risk 4. appetite.
- [3-2] Network Security: Missing evidence of implemented network segmentation, firewall deployment, and network 5. traffic monitoring.
- [3-4] Application Security: No evidence of secure SDLC practices, code reviews, application testing, runtime 6. protection, or related controls is provided.
- [3-5] Data and Information Protection: No evidence of data classification policies, labeling procedures, or technical 7. controls (e.g., encryption, DLP) to protect data throughout its lifecycle.
- [3-6] Cryptography: No evidence of encryption, key management, or other cryptographic measures is presented. 8.
- [3-7] Physical and Environmental Security: No evidence of measures protecting physical access to facilities or 9. mitigating environmental threats such as fire, flood, or HVAC failures.
- [3-9] Change Management: No evidence of a documented change management process for controlling IT system 10. changes.

3. Controls Not Met

ID	Control Name	Domain	Gap
1-2	Cybersecurity Strategy	Cybersecurity Governance	Missing documented cybersecurity strategy, evidence of
2-1	Asset Management	Cybersecurity Risk Management	No evidence of identifying or maintaining an inventory of
2-2	Risk Assessment	Cybersecurity Risk Management	No evidence of regular risk assessments to identify threa
2-3	Risk Treatment	Cybersecurity Risk Management	Missing documented risk treatment plans and evidence o
3-2	Network Security	Cybersecurity Operations	Missing evidence of implemented network segmentation
3-4	Application Security	Cybersecurity Operations	No evidence of secure SDLC practices, code reviews, ap
3-5	Data and Information Protection	Cybersecurity Operations	No evidence of data classification policies, labeling proce
3-6	Cryptography	Cybersecurity Operations	No evidence of encryption, key management, or other cr
3-7	Physical and Environmental Security	Cybersecurity Operations	No evidence of measures protecting physical access to f
3-9	Change Management	Cybersecurity Operations	No evidence of a documented change management proce
3-10	Backup and Recovery	Cybersecurity Operations	No evidence of regular backups of critical data or testing
4-3	Cloud Computing Security	Third-Party and Supply Chain C	No evidence of cloud-specific security controls, data prot
5-1	Business Continuity Management	Cybersecurity Resilience	No evidence of a business continuity plan that incorporat
5-2	Disaster Recovery	Cybersecurity Resilience	No evidence of development or testing of disaster recove
6-1	Cybersecurity Awareness Program	Cybersecurity Awareness and T	No evidence of an ongoing awareness program covering
6-2	Specialized Cybersecurity Training	Cybersecurity Awareness and T	No evidence of specialized training for staff with cyberse

4. Controls Partially Met

ID	Control Name	Domain	Gap
1-3	Cybersecurity Policies and Procedures	Cybersecurity Governance	Missing evidence of formal approval of the policies and c
1-4	Cybersecurity Roles and Responsibilities	Cybersecurity Governance	Missing a comprehensive, documented list of all cyberse
1-5	Cybersecurity Risk Management	Cybersecurity Governance	No documented, organization-wide risk management pro
2-4	Compliance Management	Cybersecurity Risk Management	No documented process or evidence of continuous moni
3-1	Identity and Access Management	Cybersecurity Operations	No evidence of actual identity provisioning, enforcement
3-3	Endpoint Security	Cybersecurity Operations	No specific controls for protecting servers, workstations,
3-8	Vulnerability Management	Cybersecurity Operations	No explicit description of vulnerability assessment metho
4-1	Third-Party Risk Management	Third-Party and Supply Chain C	Missing evidence of continuous monitoring, periodic reas
4-2	Outsourcing Security	Third-Party and Supply Chain C	No evidence of ongoing enforcement, monitoring, or com
5-3	Incident Management	Cybersecurity Resilience	Missing evidence of detection mechanisms and recovery

5. Controls Met

ID	Control Name	Domain
1-1	Cybersecurity Leadership and Oversight	Cybersecurity Governance